

EBIOS Risk Manager ?

Un changement de paradigme

- SI faiblement interconnectés
- Menaces peu sophistiquées
- Règlementation peu mature
- Etat de l'art en construction

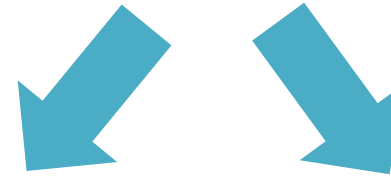
ANCIEN PARADIGME

- Bouleversement numérique
- Prolifération des menaces
- Règlementation et état de l'art matures

NOUVEAU PARADIGME



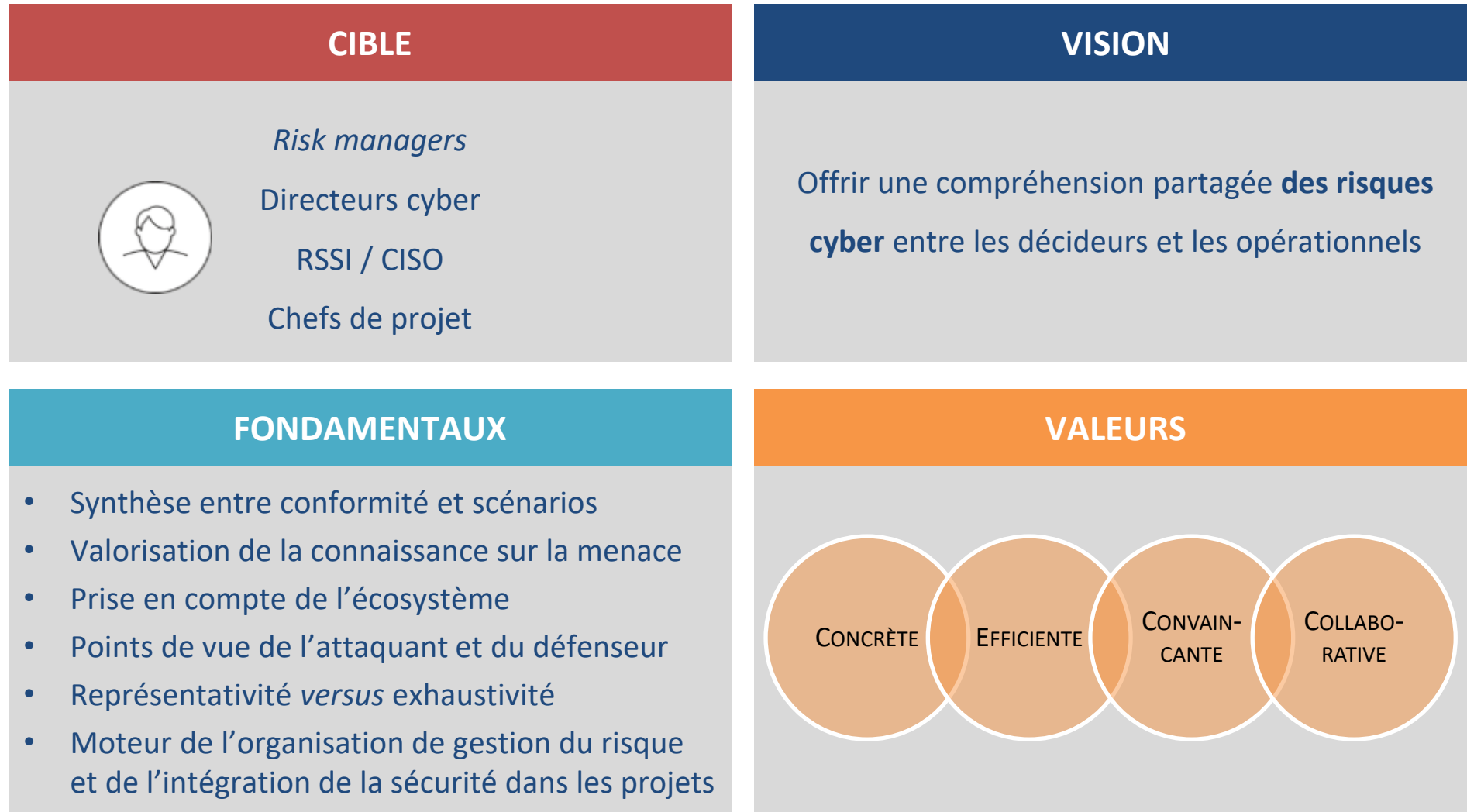
Forteresse



On est passé d'un risque technique à un risque stratégique qui touche toute l'organisation d'entreprise

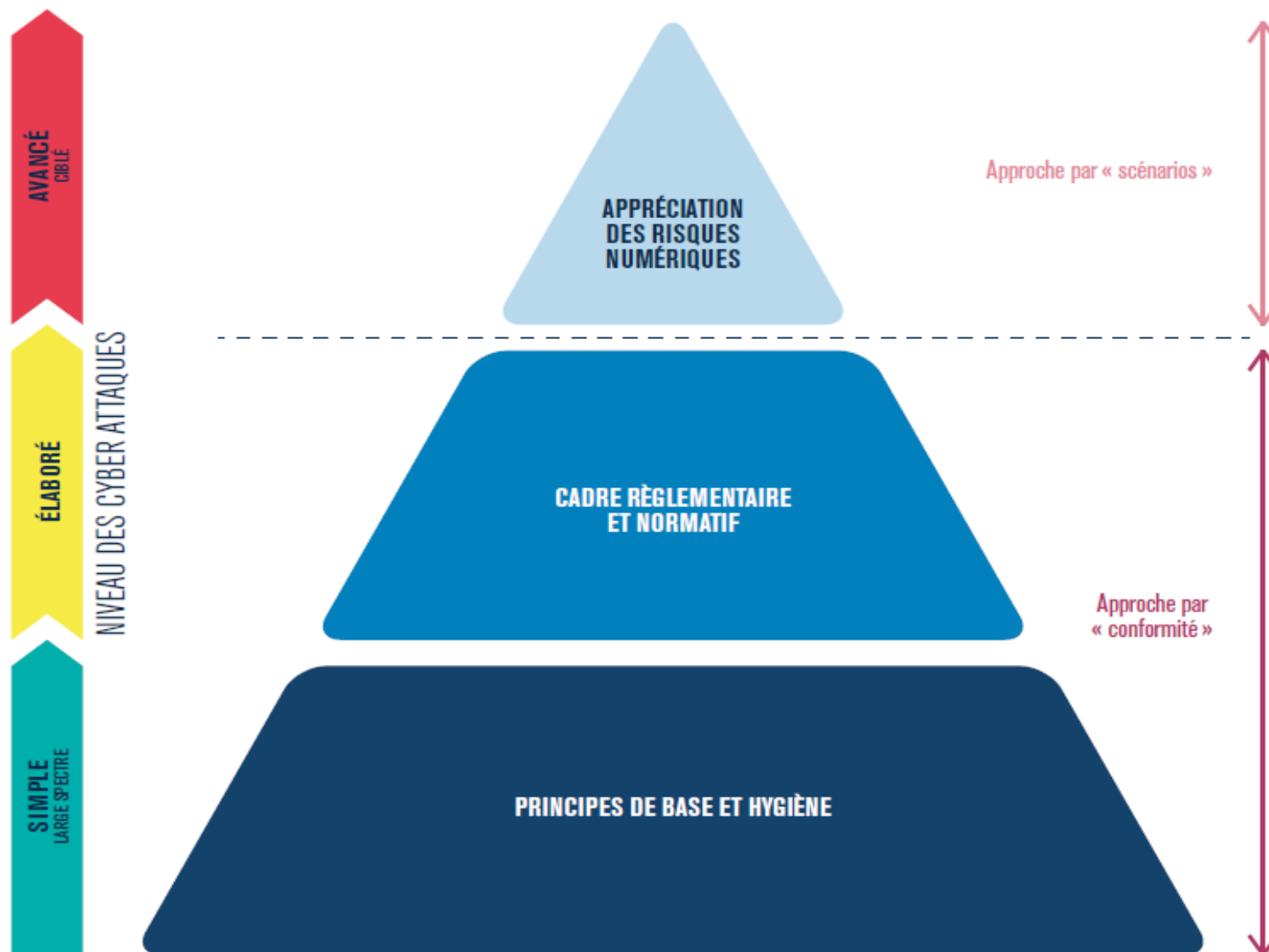
EBIOS Risk Manager ?

Carte d'identité de la méthode



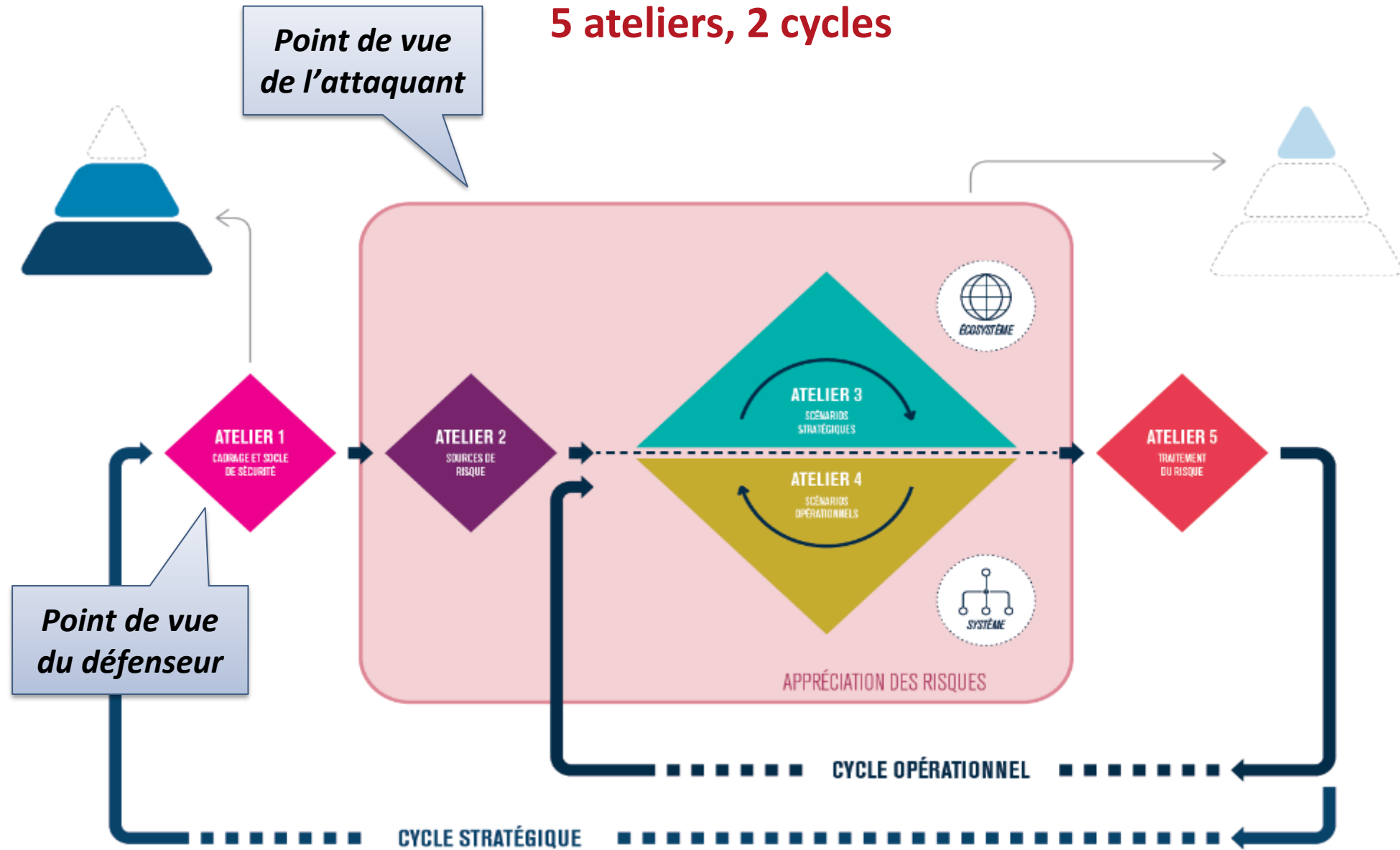
EBIOS Risk Manager ?

La pyramide du management du risque : le concept phare



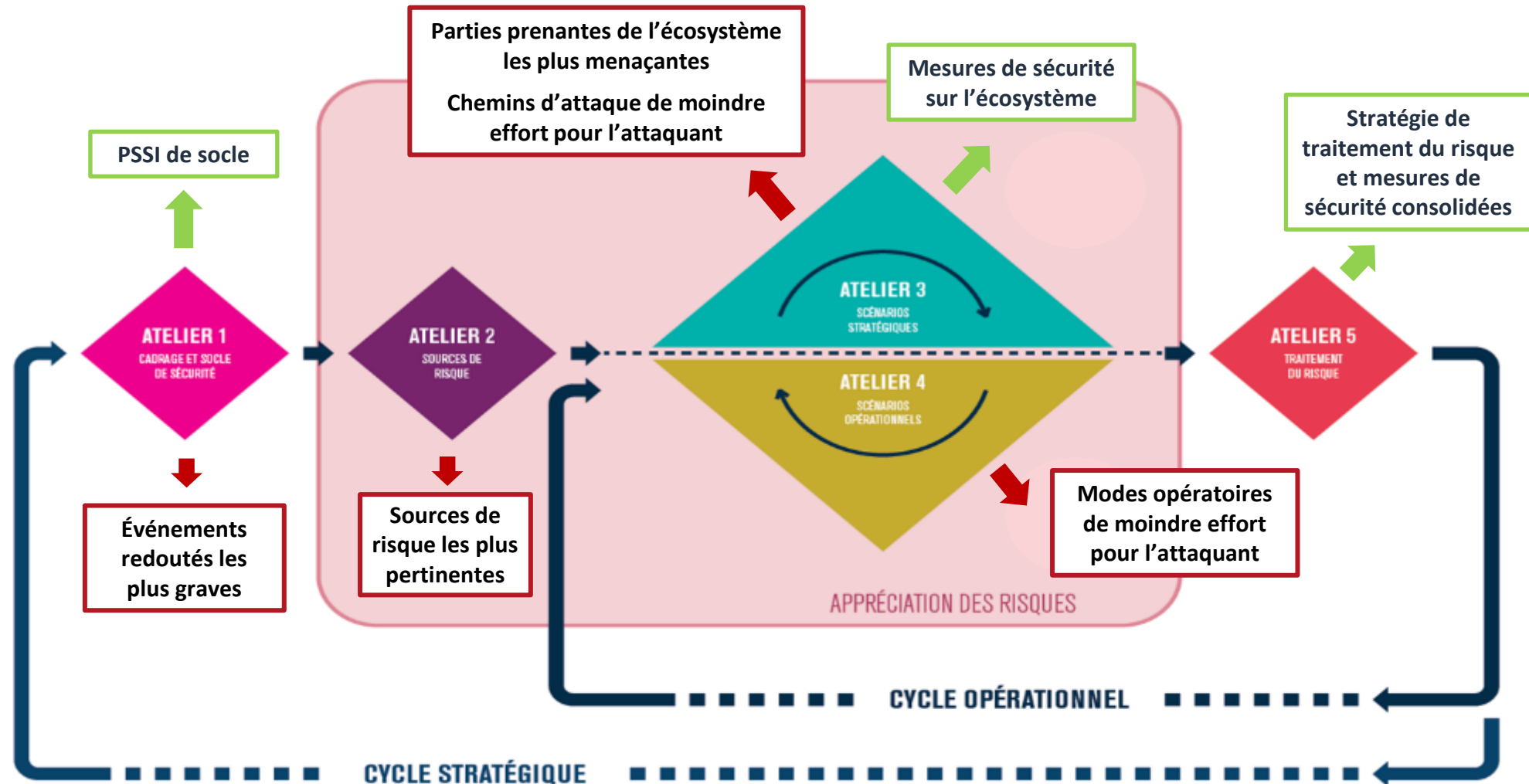
EBIOS Risk Manager ?

5 ateliers, 2 cycles



EBIOS Risk Manager ?

Une démarche productive à chaque étape



EBIOS Risk Manager ?

Adresser l'ensemble des risques numériques intentionnels

LPM, NIS

- Entrave au fonctionnement
- Sabotage

RGS, eIDAS

- Détournement ou abus d'usage
- Fraude, falsification
- Usurpation d'identité

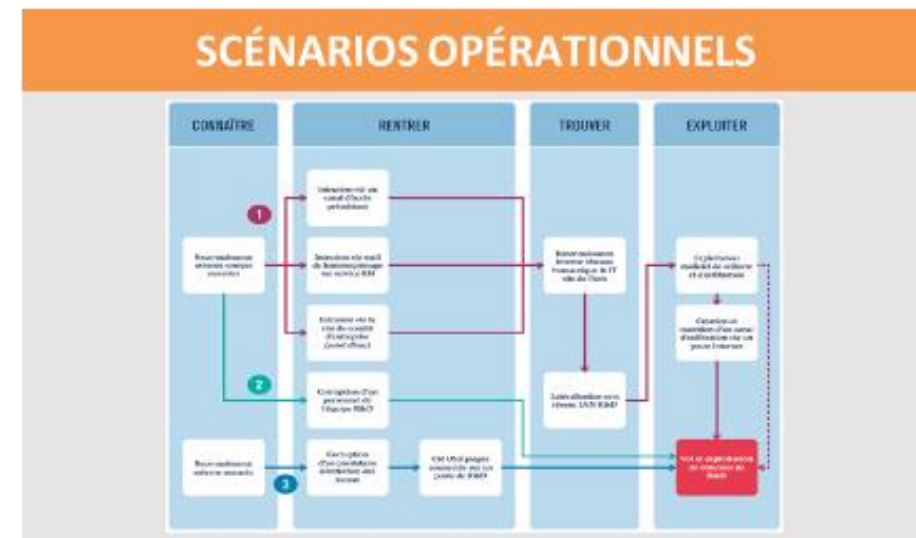
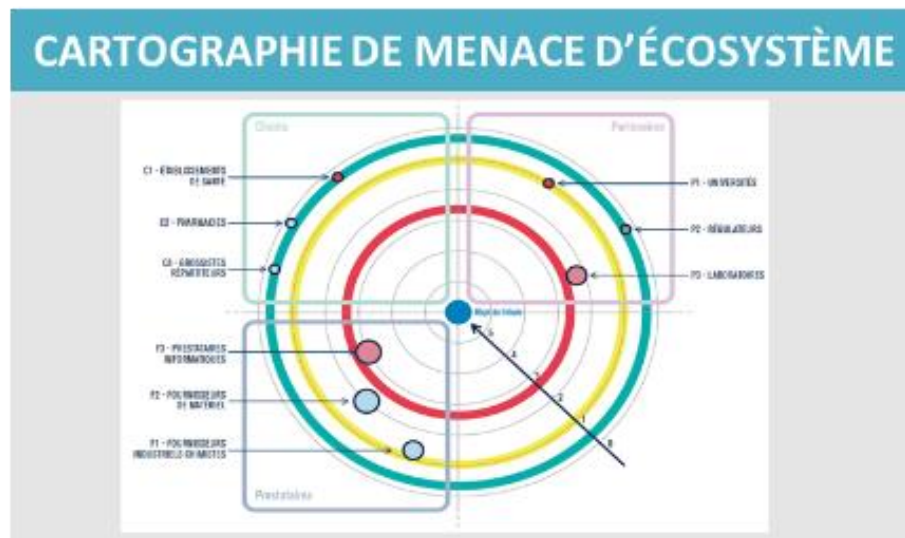
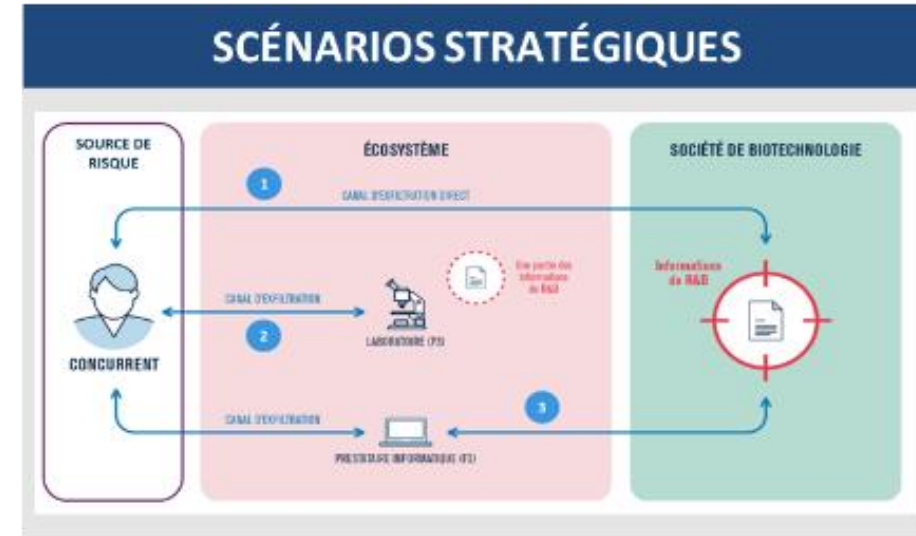
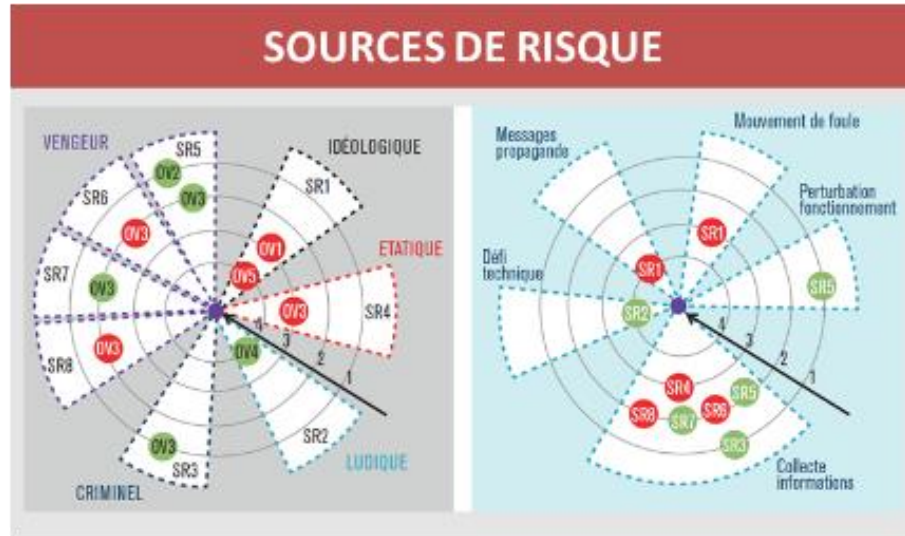
RGPD, IGI 1300, PSSIE, PPST...

- Vol de données
- Espionnage, intelligence économique

- Activisme, agitation, propagande
- Influence, déstabilisation
- Pré-positionnement
- Espionnage étatique

EBIOS Risk Manager ?

Des livrables opposables qui permettent d'orienter une décision



EBIOS Risk Manager ?

Quizz : différents usages d'EBIOS *Risk Manager*

OBJECTIF DE L'ÉTUDE	ATELIERS PRINCIPAUX À CONDUIRE OU EXPLOITER				
	1	2	3	4	5
Identifier le socle de sécurité adapté à l'objet de l'étude					
Être en conformité avec les référentiels de sécurité numérique					
Évaluer le niveau de menace de l'écosystème vis-à-vis de l'objet de l'étude					
Identifier et analyser les scénarios de haut niveau, intégrant l'écosystème					
Réaliser une étude préliminaire de risque pour identifier les axes prioritaires d'amélioration de la sécurité					
Conduire une étude de risque complète et fine, par exemple sur un produit de sécurité ou en vue de l'homologation d'un système					
Orienter un audit de sécurité et notamment un test d'intrusion					
Orienter les dispositifs de détection et de réaction, par exemple au niveau d'un centre opérationnel de la sécurité (SOC)					



EBIOS Risk Manager ?

Quizz : différents usages d'EBIOS Risk Manager

OBJECTIF DE L'ÉTUDE	ATELIERS PRINCIPAUX À CONDUIRE OU EXPLOITER				
	1	2	3	4	5
Identifier le socle de sécurité adapté à l'objet de l'étude	X				
Être en conformité avec les référentiels de sécurité numérique	X				X
Évaluer le niveau de menace de l'écosystème vis-à-vis de l'objet de l'étude			X		
Identifier et analyser les scénarios de haut niveau, intégrant l'écosystème		X	X		
Réaliser une étude préliminaire de risque pour identifier les axes prioritaires d'amélioration de la sécurité	X	X	X		X
Conduire une étude de risque complète et fine, par exemple sur un produit de sécurité ou en vue de l'homologation d'un système	X	X	X	X	X
Orienter un audit de sécurité et notamment un test d'intrusion			X	X	
Orienter les dispositifs de détection et de réaction, par exemple au niveau d'un centre opérationnel de la sécurité (SOC)			X	X	

Qui du défenseur ou de l'attaquant a l'avantage ?

Votre avis
nous
intéresse

L'ATTAQUANT A L'AVANTAGE...

- Disproportion des moyens requis entre attaque et défense
- Surface d'attaque importante
- Choix des armes et du *timing*
- Difficulté de détection et d'attribution (aisément répudiable)
- Difficulté de riposte
- Fortement industrialisable (prolifération)
- Exploitation des négligences et vulnérabilités

... MAIS IL N'EST PAS TOUJOURS A SON AVANTAGE !

- Une fois entré dans le SI, l'attaquant perd l'avantage du terrain et doit tâtonner
- Le moindre faux pas peut lui être fatal et ruiner des mois de préparation
- Il peut commettre des erreurs par imprudence, excès de confiance ou précipitation
- Un défenseur avisé peut placer des *honey pots* pour le leurrer

➔ **Aucune défense 100% sûre... mais aucune attaque 100% garantie pour l'attaquant**
EBIOS Risk Manager offre les conditions pour agir sur le « ROI » de l'attaquant



“ Le cyberattaquant agissant dans une logique d’analyse de risque, la méthode *EBIOS Risk Manager* a été conçue dans une logique d’attaquant ”

EBIOS *Risk Manager* est compatible avec les cadres internationaux



Ressources disponibles



EBIOS Risk Manager

- <https://www.ssi.gouv.fr/guide/la-methode-ebios-risk-manager-le-guide/>

AGILITÉ ET SÉCURITÉ NUMÉRIQUES

- www.ssi.gouv.fr/guide/agilite-et-securite-numeriques-methode-et-outils-a-lusage-des-equipes-projet/



L'HOMOLOGATION DE SÉCURITÉ EN NEUF ÉTAPES SIMPLES

- www.ssi.gouv.fr/guide-homologation-securite

CARTOGRAPHIE DU SYSTÈME D'INFORMATION

- www.ssi.gouv.fr/guide/cartographie-du-systeme-dinformation/

